

Презентация по выполнению индивидуального проекта №5

Основы информационной безопасности

Бызова М. О.

09 мая 2025

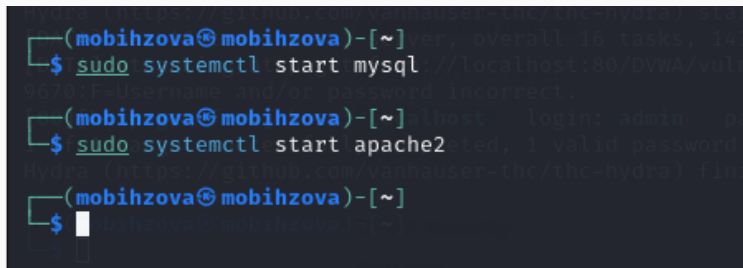
Российский университет дружбы народов, Москва, Россия

Информация

Научиться использовать Burp Suite.

Выполнение лабораторной работы

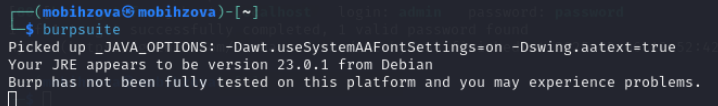
Запускаю локальный сервер, на котором открою веб-приложение DVWA для тестирования инструмента Burp Suite



```
(mobihzova@mobihzova)-[~]ver, overall 16 tasks, 14
$ sudo systemctl start mysql://localhost:80/DVWA/vuln
9670:F=Username and/or password incorrect.
(mobihzova@mobihzova)-[~]alhost login: admin pa
$ sudo systemctl start apache2eted, 1 valid password
Hydra (https://github.com/vanhauser-thc/thc-hydra) fin
(mobihzova@mobihzova)-[~]
$
```

Рис. 1: Запуск локального сервера

Запускаю инструмент Burp Suite



```
(mobihzova@mobihzova)-[~] $ burpsuite
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Your JRE appears to be version 23.0.1 from Debian
Burp has not been fully tested on this platform and you may experience problems.
```

Рис. 2: Запуск приложения

Открываю сетевые настройки браузера, для подготовке к работе

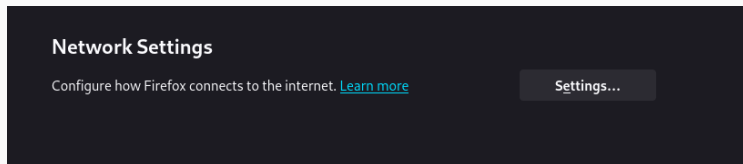


Рис. 3: Сетевые настройки браузера

Выполнение лабораторной работы

Изменение настроек сервера для работы с проху и захватом данных с помощью Burp Suite

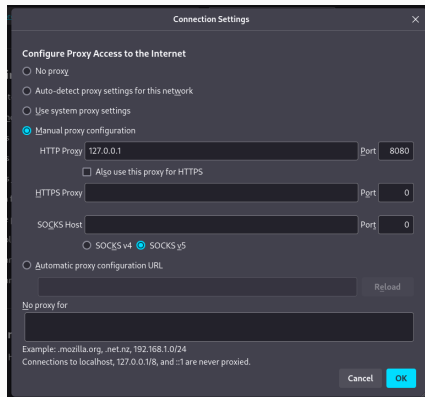


Рис. 4: Настройки сервера

Выполнение лабораторной работы

Изменяю настройки Прoxy инструмента Burp Suite для дальнейшей работы

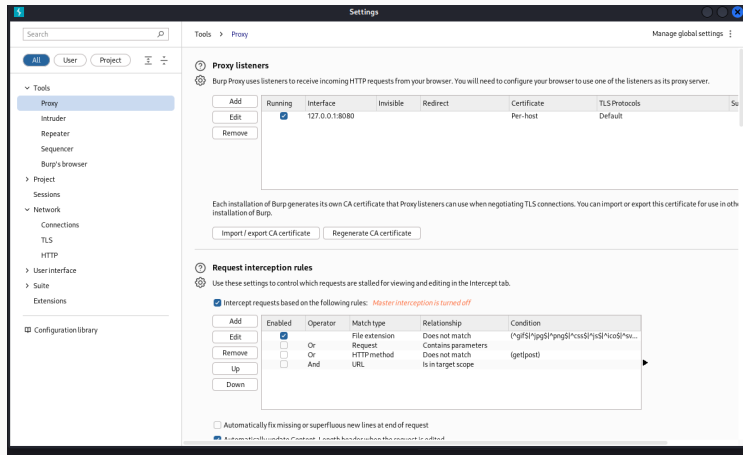


Рис. 5: Настройки Burp Suite

Во вкладке Proxy устанавливаю “Intercept is on”

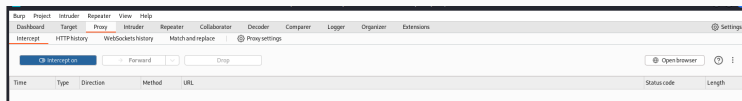


Рис. 6: Настройки Proxy

Чтобы Burp Suite исправно работал с локальным сервером, необходимо установить параметр `network.allow_hijacking_localhost` на `true`

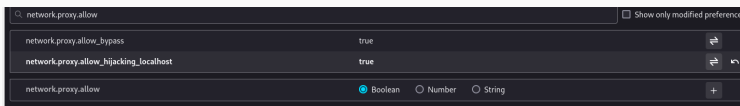


Рис. 7: Настройки параметров

Пытаюсь зайти в браузере на DVWA, тут же во вкладки Проху появляется захваченный запрос. Нажимаем “Forward”, чтобы загрузить страницу

Time	Type	Direction	Method	URL	Status code	Length
13:26:36.6 ms...	HTTP	→ Request	POST	http://a.pki.goog/we2		
13:26:37.6 ms...	HTTP	→ Request	POST	http://a.pki.goog/we2		
13:29:24.6 ms...	HTTP	→ Request	GET	http://127.0.0.0/DVWA/login.php		

Рис. 8: Получаемые запросы сервера

Загрузилась страница авторизации, текст запроса поменялся

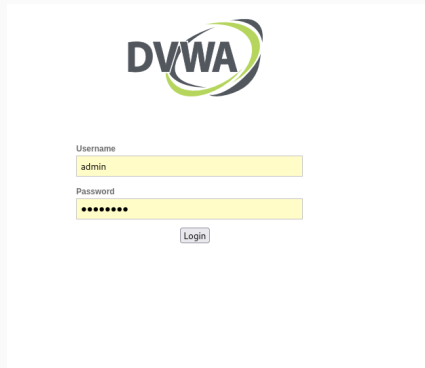
The image shows the login page of the DVWA (Damn Vulnerable Web Application). At the top center is the DVWA logo, which consists of the letters 'DVWA' in a bold, dark font, with a stylized green and grey swoosh to its right. Below the logo, there are two input fields. The first is labeled 'Username' and contains the text 'admin'. The second is labeled 'Password' and contains a series of black dots. Below these fields is a 'Login' button.

Рис. 9: Страница авторизации

История запросов хранится во вкладке Target

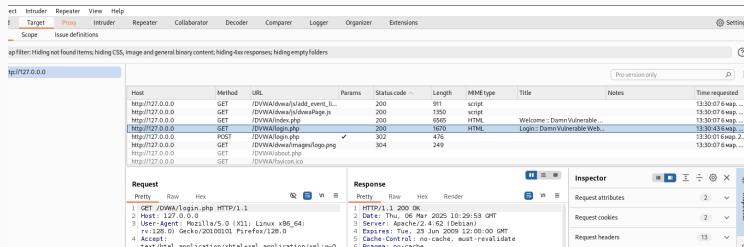


Рис. 10: История запросов

Выполнение лабораторной работы

Попробуем ввести неправильные, случайные данные в веб-приложении и нажмем Login. В запросе увидим строку, в которой отображаются введенные нами данные, то есть поле для ввода

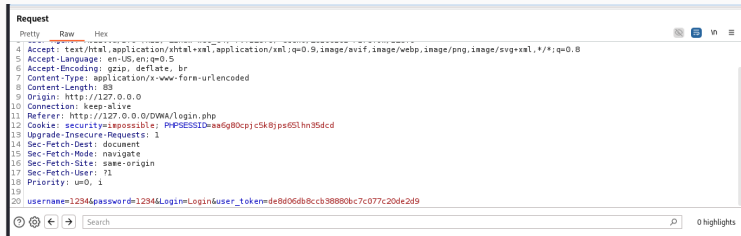


Рис. 11: Ввод случайных данных

Выполнение лабораторной работы

Этот запрос так же можно найти во вкладке Target, там же жмем правой кнопкой мыши на хост нужного запроса, и далее нажимаем “Send to Intruder”

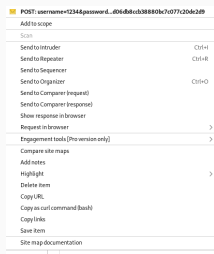


Рис. 12: POST-запрос с вводом пароля и логина

Выполнение лабораторной работы

Попадаем на вкладку Intruder, видим значения по умолчанию у типа атаки и наш запрос

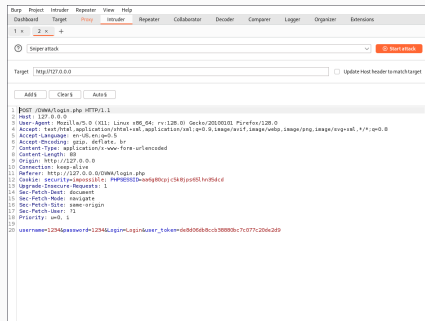


Рис. 13: Вкладка Intruder

Выполнение лабораторной работы

Изменяем значение типа атаки на Cluster bomb и проставляем специальные символы у тех данных в форме для ввода, которые будем пробивать, то есть у имени пользователя и пароля



Рис. 14: Изменение типа атаки

Выполнение лабораторной работы

Так как мы отметили два параметра для подбора, то нам нужно два списка со значениями для подбора. Заполняем первый список в Payload setting

Start attack

Payloads

Payload position: No payload positions configured

Payload type: Simple list

Payload count: 6

Request count: 6

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste admin

Load... password

Remove passwd

Clear 123456

Deduplicate dddddd

ffff

Add

Add from list... [Pro version only]

Рис. 15: Первый Simple list

Выполнение лабораторной работы

Переключаемся на второй список и добавляем значения в него. В строке request count видим нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль

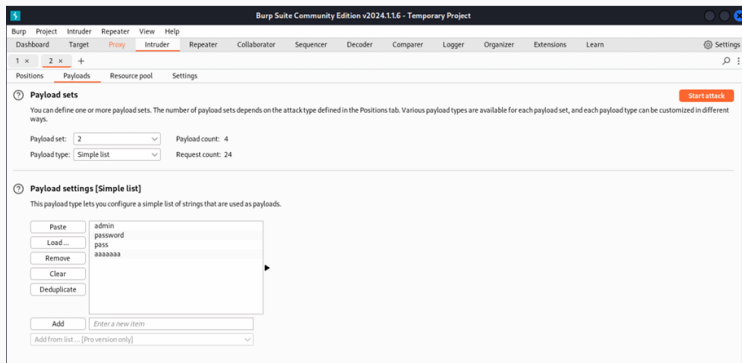
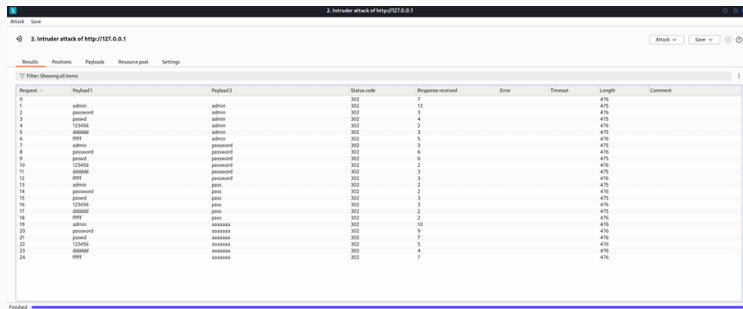


Рис. 16: Второй Simple list

Выполнение лабораторной работы

Запускаю атаку и начинаю подбор



Attack Save

2. Intruder attack of http://127.0.0.1

Attack Save

Results Positions Payloads Resource pool Settings

Filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			302	7			476	
1	admin	admin	302	13			476	
2	password	password	302	3			476	
3	password	admin	302	4			476	
4	123456	admin	302	2			476	
5	000000	admin	302	3			476	
6	!!!!	admin	302	5			476	
7	admin	password	302	3			476	
8	password	password	302	6			476	
9	password	password	302	6			476	
10	123456	password	302	2			476	
11	000000	password	302	3			476	
12	!!!!	password	302	3			476	
13	admin	pass	302	2			476	
14	password	pass	302	2			476	
15	password	pass	302	3			476	
16	123456	pass	302	3			476	
17	000000	pass	302	2			476	
18	!!!!	pass	302	2			476	
19	admin	aaaaaa	302	10			476	
20	password	aaaaaa	302	9			476	
21	password	aaaaaa	302	7			476	
22	123456	aaaaaa	302	5			476	
23	000000	aaaaaa	302	4			476	
24	!!!!	aaaaaa	302	7			476	

Finished

Рис. 17: Запуск атаки

Выполнение лабораторной работы

При открытии результата каждого post-запроса можно увидеть полученный get-запрос, в нем видно, куда нас перенаправило после выполнения ввода пары пользователь-пароль. В представленном случае с подбором пары admin-admin нас перенаправило на login.php, это значит, что пара не подходит

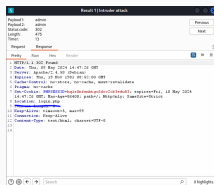


Рис. 18: Результат запроса

Выполнение лабораторной работы

Проверим результат пары admin-password во вкладке Response, теперь нас перенаправляет на страницу index.php, значит пара должна быть верной

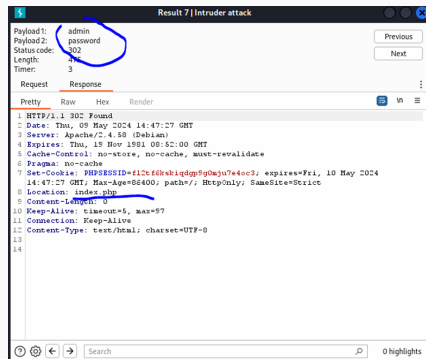


Рис. 19: Результат запроса

Выполнение лабораторной работы

Дополнительная проверка с использованием Repeater, нажимаем на нужный нам запрос правой кнопкой мыши и жмем “Send to Repeater”

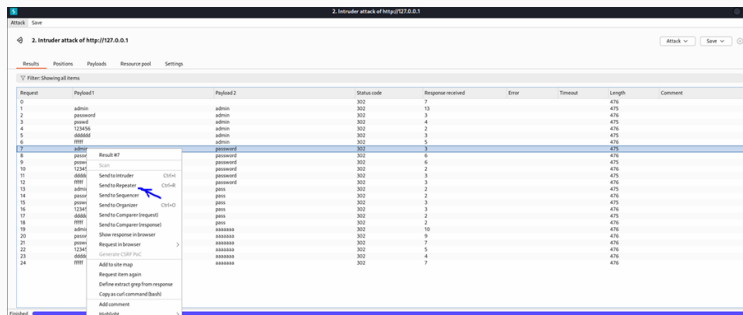


Рис. 20: Дополнительная проверка результата

Переходим во вкладку “Repeater”

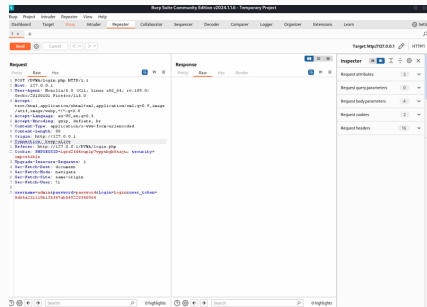


Рис. 21: Вкладка Repeater

Выполнение лабораторной работы

Нажимаем “send”, получаем в Response в результате перенаправление на index.php

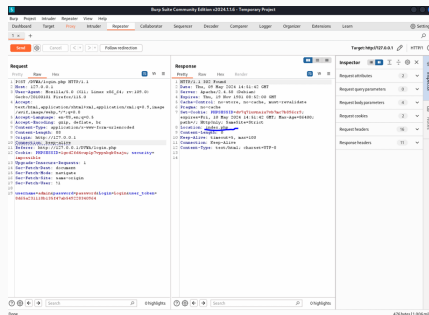


Рис. 22: Окно Response

Выполнение лабораторной работы

После нажатия на Follow redirection, получим неcompiled html код в окне Response

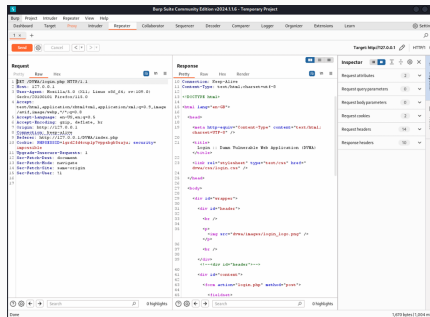


Рис. 23: Изменение в окне Response

Выполнение лабораторной работы

Далее в подокне Render получим то, как выглядит полученная страница

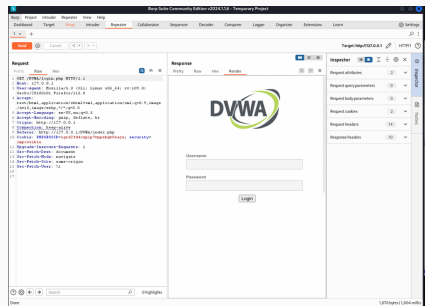


Рис. 24: Полученная страница

При выполнении лабораторной работы научилась использовать инструмент Burp Suite.